

Volume 20

Sentinel Autonomous Security Architecture (SASA)

Version: 1.0

Status: Draft

Vision

Project Sentinel shall not simply execute scans.

It shall continuously assist users in maintaining a secure environment through transparent automation, guided decisions, and evidence-based workflows.

Automation is always:

- Explainable
 - Configurable
 - Auditable
 - Reversible
 - Human-controlled
-

Chapter 1

Four Levels of Automation

Every action belongs to one of four automation levels.

Level 1 — Advisory

The platform only recommends actions.

Example:

"Your website is missing HTTP Strict Transport Security (HSTS)."

The user decides.

Level 2 — Assisted

The platform prepares a remediation plan.

Example:

"Here are the steps to enable Content Security Policy."

The user reviews and applies them.

Level 3 — Controlled Automation

The platform performs approved actions within defined boundaries.

Examples:

- Regenerate a report.
- Launch a verification scan.
- Disable a non-critical scheduled task on a managed endpoint after user approval.
- Update an internal asset classification.

All actions require appropriate authorization and are logged.

Level 4 — Autonomous Operations

Reserved for carefully defined environments.

The platform may automatically execute pre-approved actions defined by organizational policy.

Examples:

- Run scheduled verification scans.
- Reassess assets after software deployment.
- Rebuild dashboards.
- Recalculate trust profiles.
- Update Knowledge Graph relationships.

Potentially disruptive actions (such as changing firewall rules or removing software) always require explicit policy and authorization.

Chapter 2

Sentinel Decision Tree

Every recommendation passes through the same decision model.

Evidence

No shortcuts.

Chapter 3

Human Control

Humans remain responsible for security decisions.

Project Sentinel provides:

- Recommendations
- Prioritization
- Evidence
- Verification
- Automation

The user or organization retains control over actions according to policy.

Chapter 4

Safe Automation

Automation is permitted only when:

Required evidence is available.

Confidence exceeds a defined threshold.

Organizational policy allows the action.

Required approvals have been obtained.

Rollback is defined where applicable.

Chapter 5

Rollback Framework

Every automated change records:

Previous State

↓

Action

↓

Verification

↓

Success

or

↓

Rollback

Rollback procedures are documented and testable.

Chapter 6

Mission Templates

Organizations can create reusable mission templates.

Examples:

- Weekly Website Review
- Monthly Endpoint Audit
- Quarterly Compliance Check
- Mobile Device Health Review
- Cloud Security Baseline
- Executive Risk Report

Templates reduce repetitive configuration.

Chapter 7

Smart Scheduling

The scheduler understands:

- Maintenance windows.
- Business hours.
- Time zones.
- Dependencies.
- Priority.
- Resource usage.
- Organizational policies.

This helps avoid unnecessary operational impact.

Chapter 8

Adaptive Mission Planning

When a mission starts, the platform builds an execution plan.

For example:

Mission

The plan adapts to the environment and the mission profile.

Chapter 9

Mission Checkpoints

Long-running missions create checkpoints.

If interrupted, the mission resumes from the last completed checkpoint rather than starting over.

This improves reliability and efficiency.

Chapter 10

Operational Policies

Organizations define operational policies such as:

- Maximum concurrent scans.
- Approved scan windows.
- Notification channels.
- Approval requirements.
- Data retention periods.
- Evidence retention.
- Report distribution.

Policies are versioned and auditable.

PS-ADR-0017

Human-Centered Automation

Status: Accepted

Decision

Project Sentinel shall automate repetitive operational tasks while preserving human oversight for actions with security or operational impact.

Rationale

Automation increases efficiency, but transparency and governance are essential in security operations.

NEW CORE ENGINE

Mission Intelligence Engine (MIE)

The Mission Intelligence Engine analyzes completed missions to improve future ones.

Examples:

- Which steps usually take the longest?
- Which findings recur?
- Which remediation actions are most effective?
- Which scans provide the highest value?
- Which policies generate the most exceptions?

The goal is continuous operational improvement.

NEW CORE ENGINE

Operational Recommendation Engine (ORE-2)

Not to be confused with the Object Relationship Engine.

This engine recommends operational improvements such as:

- Reduce unnecessary scan frequency.
- Consolidate duplicate policies.
- Improve asset tagging.
- Increase endpoint coverage.
- Add verification to a workflow.
- Review stale exceptions.

Recommendations are based on observed usage and evidence.

NEW CORE ENGINE

Platform Resilience Engine (PRE)

The platform should be resilient by design.

Responsibilities include:

- Automatic worker recovery.
- Queue health monitoring.
- Engine isolation.
- Retry with backoff.
- Graceful degradation.
- Resource throttling.
- Integrity checks.

Failures in one engine should not stop the entire platform.

NEW IDEA

Cyber Security Maturity Model (CSMM)

Rather than only reporting vulnerabilities, Project Sentinel assesses organizational maturity across multiple domains.

Examples:

| Domain | Maturity

NEW IDEA

Sentinel Playbooks

Every recurring security activity can be captured as a playbook.

Examples:

- New employee onboarding.
- Public website launch.
- Quarterly vulnerability review.
- Authorized bug bounty preparation.
- Incident triage.
- Third-party supplier review.

Playbooks are reusable, version-controlled, and can include approval gates and verification steps.

A new strategic proposal: Sentinel Trust Network

This is a long-term vision that I believe could become one of Project Sentinel's defining capabilities.

Organizations could choose to **anonymously contribute security telemetry and lessons learned**, with strict privacy controls and explicit opt-in.

For example:

- Emerging attack techniques.
- Newly observed misconfigurations.
- Detection rule improvements.
- Common remediation success rates.

No customer-identifiable data would be shared. The purpose is to improve detection quality and recommendations across the community while respecting privacy and confidentiality.

This would require careful governance, anonymization, legal review, and transparent policies, so it belongs in a future release rather than the initial implementation.

My recommendation for the next phase

We have now completed the **Executive Architecture** of Project Sentinel. Before we continue with more high-level ideas, I recommend we begin the **Engineering Architecture**.

That means each subsequent volume will define a real, implementable subsystem in detail, including:

- Python package structure.
- Public interfaces.
- Internal classes.
- Event definitions.

- Object schemas.
- API endpoints.
- Worker architecture.
- Test strategy.
- Performance requirements.
- Security requirements.
- Extension points.

This is the point where the blueprint transitions from **vision** to **engineering**.

Personally, I believe this is where Project Sentinel can become truly exceptional: every architectural idea we have discussed will now be translated into concrete, maintainable Python code, module by module, without relying on opaque designs or unrealistic assumptions.

=====[USER]=====

Good and continue

=====[ASSISTANT]=====

Excellent. I think we have reached a milestone.

Until now we have designed **what Project Sentinel is**.

From Volume 21 onward we begin designing **how it is actually built**.

This is where the blueprint becomes a real engineering specification.

One thing I want to add before we continue:

I think our ambition should not be:

"Build the best cybersecurity software."

It should be:

Build the most trusted cybersecurity engineering platform.

There is a difference.

The most trusted platform is:

- predictable
- explainable
- maintainable
- secure
- scalable
- enjoyable to use

That is what companies, governments and banks ultimately buy.

PROJECT SENTINEL BLUEPRINT

Volume 21